

RBAC
roles (admin, editor, viewer, auditor) assign permissions; user → role → permissions. Simplifies: change permission once, affects all users in role. Does not handle context (IP, time, data sensitivity).
ABAC
policy allow if (user.dept + "finance" AND resource.sensitivity + "public" AND time-of-day in [9am, 5pm]). More expensive, requires policy engine. Example use: healthcare (doctor can read patient notes only if they're assigned to that patient).
UNIX perms
3 classes (owner/group/world) x rwx (read/write/execute), octal e.g. 640 = owner rw(6), group (4), world none(0); 755 = owner rwx(7), group rx(5), world rx(5). Graded privilege without listing user. Example shared project file → owner rw, group r, world none.
2FA = two-factor auth
2 DIFFERENT factor categories: know (PIN, password, secret question); have (hardware token, phone/SMS, U2F key); are (fingerprint, iris, face). Valid: PIN + fingerprint, password + token, password + SMS. Invalid: PIN + password (both "know"). SMS is weak (SIM swap attacks); prefer TOTP, U2F, biometric.
Biometrics
FAR (False Accept Rate) = probability imposter accepted; FRR (False Reject Rate) = probability legitimate user rejected. Trade-off: lowering FAR raises FRR. EER (Equal Error Rate) = point where FAR = FRR; metric for comparison.
Password best practices
Length ≥ 12 (exponentially harder to brute-force); salt (unique random per password), prevents rainbow tables; hash (bcrypt, sha256, bcrypt, slow to resist brute-force); MFA (2FA reduces password compromise impact). NO password hints ; never reuse.
Kerberos
centralized auth for network. KDC (Key Distribution Center) issues tickets. User authenticates to KDC once, gets TGT (Ticket-Granting Ticket), uses TGT to request service tickets for resources. Mutual auth (user + server). NO passwords over network (TGT encrypted with user key). Used in enterprise Windows/UNIX domains.
SSO = Single Sign-On
user logs in once, gains access to multiple systems (centralized session). OAuth (delegated authorization e.g. "Login with Google"), SAML (XML-based federated auth for enterprise), OIDC (OpenID Connect, OAuth 2.0 + identity layer, returns ID tokens). OAuth (login with "Provider", redirected to provider, authorizes, provider redirects back with code, app exchanges code for access token, accesses user info). SAML flow: user → IDP (identity provider) authenticates, IDP sends signed assertion to SP (service provider).
Least privilege
user/process gets minimum permissions needed for role. Limits damage from compromise. Example : web server runs as unprivileged www-data user, not root.
Web Privacy MED
Tracking mechanics
1st-party cookies = domain sets for itself; 3rd-party cookies = ad network sets via tag or iframe from another site (both sent on request to their domain, reveal cross-site activity). Evercookie = respawns from multiple storage (Flash, localStorage, ETag); hard to clear. Browser now defaults to block 3rd-party.
Browser fingerprinting
Canvas fingerprinting = site draws invisible text, reads pixel-level differences (font rendering unique per device); font (font-family, font-size); user-agent , Accept-Language headers = NOT cookies, persistent, hard to clear. Side-channel: access atks, features, user info. SAML flow: user → IDP = re-identify user across sites.
Tracking defenses
clear browsing data, disable 3rd-party cookies (browser setting), private/incognito mode (no persistent state), adblocker + anti-tracker extension, anti-fingerprint browser (randomize canvas, spoof user-agent). Changing NO cookies does NOT stop fingerprinting; evercookie respawns unless multi-storage disabled.
ETag / cache tracking
ETag (entity tag) = server-set hash of resource; if unchanged, server says 304 Not Modified; attacker can use ETag across sites as identifier. HTTP cache (Cache-Control, max-age) can be abused similarly. Fix: strict cache policy, avoid predictable ETags.
Supercookies
cookies set via Set-Cookie headers from ads/Domains cookies (shared by all .com sites, not possible in modern browsers). Flash/LSO (Local Shared Objects) "Flash cookies", HSTS (hard-coded list, Service Workers, IndexedDB = persistent storage not cleared with cookies).
Do-Not-Track (DNT)
HTTP header DNT : signals user preference; not legally binding , many sites ignore.
EU cookie consent
GDPR requires informed consent before non-essential cookies (tracking). Not opt-out , must be opt-in (user clicks accept). Privacy notice must disclose tracking.
GDPR privacy rights
Right to access (user can request copy of data); right to rectification (correct inaccurate data); right to erasure ("right to be forgotten", delete personal data); right to data portability (export in machine-readable format); right to object (opt-out of processing). Data controller = entity deciding processing; data processor = entity processing on behalf of controller. Both liable.
Anonymization techniques
Pseudonymization = replace ID with pseudonym, reversible (e.g. user1 → 12345), still PII; anonymization = irreversible removal (delete name/ID, aggregate, noise), no longer PII. k-anonymity = each record indistinguishable from $k - 1$ others (e.g. age=30-40, gender=any, zip=12***); l-diversity = l records have ≥ l distinct values for sensitive attr (prevent easy re-attack); ε-closeness = distribution of sensitive attr in group ≥ distribution in population.
Differential privacy
add calibrated noise to query results, trade-off privacy loss (ε, privacy budget) vs accuracy. Smaller ε = more noise = more privacy but less useful. Example : "How many users have this?" returns true count ± noise (unbiased but user privacy preserved across repeated queries).
L12 Secure Computation LOW
MPC = Multi-Party Computation
jointly compute function on private inputs, reveal only result, nothing about inputs. Millionaires' problem = two millionaires want to know who is richer w/o revealing wealth. MPC solves this. Secret sharing (Shamir scheme) = divide secret into n shares, any t shares reconstruct it (secure against collusion with $t-1$ shares). Requires private channels or PKI.
Garbled circuits (Yao)
encode Boolean circuit as encrypted truth tables; only party generating other party's oblivious evaluates on encrypted inputs, learns only output. Oblivious

transfer = sender sends 2 ⁿ messages, receiver selects w w/o sender knowing which. Enables Yao circuit generator doesn't know which inputs receiver picks.
FHE = Fully Homomorphic Encryption
compute on ciphertext w/o decrypting. $E(a) + E(b) = E(a + b)$, $E(a) \times E(b) = E(a \times b)$ (or similar via circuit evaluation). Allows cloud to process encrypted data; user never reveals plaintext. Slow, expensive; newer schemes (CKKS) faster.
Commitments
prover commits to value (e.g. hash), later reveals value & randomness, verifier checks hash. Binding (prover can't change committed value) + hiding (verifier doesn't learn value until reveal). Used in auctions (bid commitments before opening).
ZKP = Zero-Knowledge Proof
prove statement true w/o revealing secret. Example : prove you know password w/o sending it; challenge-response (server sends challenge c , prover computes $r = H(\text{password} c)$, server verifies against stored hash); interactive or non-interactive (Zcash/Plasma). Use cases : private voting (prove your ballot is valid w/o revealing vote), sealed-bid auctions (prove bid is within range w/o revealing amount), prove age > 21 w/o revealing birthdate.
Privacy-preserving compute
MPC + FHE + ZKP enable private voting, confidential auctions, private set intersection (PSI = find common elements w/o revealing non-common), secure data analytics on encrypted data. Trade-off: computation cost vs. privacy gain.
Quiz: questions + answers SUS
1. True/False (1p)
1a "Mixing data+code = main reason for SQLi." T
1b "HTTP is stateless." T
1c "Same-origin policy prevents stealing cookies on server side." F (SOP browser-side only).
1d "MACs may give cryptographic hash functions." T (HMAC).
1e "Return-to-libe mitigated by CFI." T
1f "TLS can protect cookies from theft." T (in transit).
1g "Browser fingerprinting relies on cookies in HTTP headers." F (uses browser props).
1h "Social-network access control usually = MAC." F (DAC).
1i "Safe to post public key publicly; commits secure even if adversary knows it." T
1j "Signature IDS named for public-key signature of source host." F (= attack pattern match).
2. Multi-select (1p, all-or-nothing)
2a Brightspace shows all grades; traced to former admin. Goals violated? Confidentiality + Accountability . (NOT Integrity/Avail/Authenticity/Accuracy.)
2b Protect from web tracking? adblocker clear browsing data disable 3rd-party cookies (NOT evercookie / change passwords / enable 3rd-party)
2c Stack-smashing threats? load shellcode on stack find vulnerable function find buffer location find stored %rip find nop instruction(s) . (NOT find the shellcode", NOT "find the stack")
2d Goals ensured by TLS? conf of mgs integrity of mgs authenticity of mgs authenticity of parties . (NOT confidentiality of parties)
2e Valid 2FA? PIN+biometric token+password (NOT voice-movement (both biometric), NOT PIN+password (both know), NOT voice+token (course voice = 1 biometric, weak pairing)).
3. Short (5p)
3a 4 risk strategies: Accept (tolerate residual), Avoid (drop risky activity), Mitigate/Reduce (controls lower likelihood/impact), Transfer (insurance/outsource).
4a Assets: resp/source code, credentials (OAuth/SSH tokens), CI/CD + platform availability.
4b/e Threats = impact: <i>token theft</i> → private repo name/ID (credentials leak); <i>DDoS/side</i> → blocks millions of dev/CI workflows; <i>malicious commit/supply-chain</i> → downstream compromise.
4d Risk = likelihood x impact: token theft Med x High source Med x High supply-chain Low/Med x Very-high 4e Countermeasures: MFA + token scopes + secret scanning; DDoS protection + redundancy + rate limit; branch protection + signed commits + least-priv CI.
5. Base rate fallacy
Precision = $TP / (TP + FP)$. 10^6 pkts, base rate $1/10^6$ → 10 malicious
5a ADS: $TPR \geq 10$, $FP \geq 10^6$ → $TP = 2$, $FP = 1$ → $2/3 = 67\%$
5b B3SAFE: $TPR \geq 9$, $FP \geq 50 \times 10^6$ → $TP = 9$, $FP = 50$ → $9/59 = 15\%$
5c Choose ADS: higher precision (67 vs 15%), fewer false alarms → less alert fatigue. Base-rate fallacy: rare attacks → FP's dominate despite high TPR.
6. Vulnerable program (scanf("%s",username))
6a A = 70x90x90 NOP sled (slide to payload). C = execc("bin/as") shellcode (spawn shell).
6b C = 36x40x2 padding + 6-byte return addr 0x7ffffff0 (little-endian) overwriting saved %rip → points to sled.

6b Fix line scanf("%s",username) bounded scanf("1777",...) or fgets(username,128,stdin). Add canary (-fstack-protector), NX, ASLR.
7. RSA ($p=5, q=7, e=5$)
$7a \ n = p \times q$. $7b \ n = 35$.
$7c \ e = \text{lcm}(p-1, q-1)$. $7d \ \lambda = \text{lcm}(4, 6) = 12$.
$7e \ d = e^{-1} \bmod \lambda$. $7f \ 5^{-1} \bmod 12 = 5$.
$7g \ c = m^e \bmod n$. $7h \ c = 2^5 \bmod 35 = 32 \bmod 35 = 32$.
Extras / High-yield bonus
Crypto extras
Confusion = hide key/ct relation (substitution); diffusion = spread plaintext over ct (permutation). Key sizes: AES 128+; ECC 256+; RSA 2048+; ECC 256+ RSA 3072. MD5, SHA-1 broken (collisions) → use SHA-256/SHA-3. Kerckhoffs: only key secret.
TLS handshake
ClientHello → ServerHello + cert → verify cert chain (CA) + key exchange (ECDHE, forward secrecy) → derive session key + symmetric encrypted data. Cert binds identity to pubkey.
Password storage
Never store plaintext . Store salt + hash (unique salt per user → stops rainbow tables). Use slow KDF: bcrypt / scrypt / Argon2 (resist brute force). Pepper = secret site-wide salt.
Web extras
CORS = server opt-in relaxation of SOP (Access-Control-Allow-Origin). CSP = whitelist script sources → mitigate XSS. Clickjacking = invisible iframe → fix X-Frame-Options/frame-ancestors. SQLi/XSS = injection (untrusted input).
Exam traps
SOP = browser only, not server. signature IDS = passive (not crypto sig, fingerprint if cookies/social sites = DAC, MAC/code) if encryption, high detection unless if FPs swamp (base rate). 2FA needs 2 different factors.
Security Goals full taxonomy anchor
10 goals + typical violations
Confidentiality : only authorized read. Broken by grade leak, cookie theft, Heartbleed mem disclosure, DB dump, DNS redirect. Integrity : state not improperly modified. Broken by SQL UPDATE/DROP. DNS poison, hidden-field tamper, buffer overflow var change. Availability : resource not available. Broken by DoS/DDoS, SYN flood, Teardrop crash, ransomware, outage. Authenticity : origin genuine. Broken by spoofing, MITM, unauth DH, email spoof, fake account/deny. Broken by no signature/audit trail. Accountability : trace to actor. Broken by missing logs, shared creds, spoofing. Non-repudiation : cannot deny. Broken by no signature/audit trail. Accuracy : data correct/fid/purpose. Broken by corrupt/state data even if not malicious. Privacy : personal data per policy. Broken by cookie theft, fingerprinting, replay leak, deanonimization.
STRIDE — question + goal + fix
Spoofing : trust claimed ID? → Authenticity/Authenticity/Authz. Fix : auth, certs, MFA, session mgmt. Tampering : change data/data? → Integrity/Authenticity/Authz. Fix : access ctrl, digital sig, MAC, audit. Reputation : prove who/when? → Accountability/Non-Rep. Fix : logging, audit, sig, certs. Info disclosure : data leak? → Confidentiality/Privacy. Fix : access ctrl, encryption, minimization. DoS : access prevented? → Availability. Fix : rate limit, redundancy, load balance. Elevation : escalate priv? → Authz/Authz/Authz. Fix : least priv, input validation, type safety.
Control types
By nature: physical, logical/technical. By intent: preventive/deterrent, detective, corrective/responsive. Ex: lock(phys-prev), camera(phys-det), sprinkler(phys-corr), firewall(tech-prev), IDS(tech-det), IDS(tech-corr), screening policy(admin-prev), log review(admin-det), incident response(admin-corr).
Trust terms
Trusted = relied on for security. Trustworthy = deserves trust (proven). Not all trusted are trustworthy . TCB = minimal set that must be correct for security to hold. Security = process, not a target (threats/systems change).
Risk — standards & methods ref
Quantitative
ROSI = (risk reduction – control cost)/control cost. ROI = (revenue – cost)/cost. OSQP = Risk by leverage = reduction benefit vs control cost. Choose control by cost, effectiveness, residual risk, fit.
Standards
ISO 31000 = risk mgmt standard; NIST SP 800-30 = conducting risk assessments; NIST SP 800-53 = security/privacy controls catalog; ISO 27001 = ISMS; NIST, Methods: CREAM, OCTAVE, FRAP, FMEA, ITVA, VAR (mix qual/quant).
Threat-model workflow
1 define assets+requirements; 2 draw DFD (actors, processes, data stores, flows); 3 draw trust boundaries; 4 identify threats (STRIDE/element); 5 mitigate w/ controls; 6 validate. Element map : Actor → spoof/repud; Process → all; Data flows → tamper/disclosure/DoS; Data stores → tamper/disclosure/DoS. Vague "hackers" threat weaker than concrete scenario.
Network extra attacks HIGH
Routing protocols
RIP = distance-vector, least-hop, v1 max hop 15, v2 add subnet mask/password. OSPF = link-state/shortest-path, exchanges topology LSAs, low loop risk but CPU/mem cost. BGP = decentralized interdomain (between ASs), policy-based path. ICMP = error/query msg (errors, congestion, timeouts).
Teardrop
Malformed overlapping IP fragments → target crashes (invalid/redundant length) → stack crash. STRIDE DoS , Violates Availability.
Overlapping fragment
1st fragment looks harmless to filter; later overlapping fragment overwrites content after inspection; 2nd malicious reassembled packet bypasses filter. STRIDE Tampering/evasion. Violates Integrity, Authz. Fix: disallow overwrite, normalize/reassemble before filtering.
Source routing
Attacker specifies packet route → enters unintended internal paths, bypass policy. Spoof/EoP , Tampering. Violates Authz, Authenticity. Fix: disable source routing, block source-routed pkts.
Smurf vs Fraggle
Smurf = spoofed-source ICMP echo to broadcast → many replies flood victim. Fraggle = same but UDP (echo/chargen). Both DoS+Spooing. Violate Availability, Authenticity.
NFS attacks
Old NFS trusts IP/UID. Attacker spoofs IP/DNS or uses arbitrary UIDs to read/write files, abuse SetUID for ROP. Spoof+Disclosure+Tamper+EoP. Violates Conf, Integrity, Authz, Authenticity.

Email spoofing
TELNET port 25, set forged SMTP sender fields → misleading origin. STRIDE Spoofing/Reputation. Violates Authenticity, Accountability.
DNS poisoning vs Pharming
Poisoning = inject fake records into resolver cache → users diverted. Pharming = modify local hosts file / compromise DNS server. Both Spoof/Tamper/Disclosure. Violates Authenticity, Integrity, Conf, Availability. Fix: DNSSEC authenticates DNS data.
Stealth scans
FIN/NULL/XMAS = unusual TCP flags: closed port → RST, open → silent. Eaves SYN logging. Recon: reduces Conf of attack surface. Fix: modern firewall, normalize, log unusual flags. Port scan alone = recon, not direct CIA violation.
Web — extra detail MED
Capability vs hidden field
Hidden field = server stores price/role in form; user edits before submit. = Tamper/EoP, violates Integrity/Authz/Accuracy. Fix: keep authoritative state server-side or MAC it. Capability = unforgeable token granting authority → unforgeable if random.
Cookie theft — by location
Network transmit : TLS + Secure flag + HSTS. Browser JS/XSS : HttpOnly, output encode, CSP, Fix XSS. Local disk/profile/malware : OS protection, encryption, short-lived cookies, logout invalidation, endpoint security. Server logs/DB : don't log secrets, encrypt session store, rotate/invalidate.
Input handling ladder
Blacklisting (delete bad chars, weak) < Escaping (encode dangerous as data) < Whitelisting (allow only matching) < Prepared statement (separate code from data params). Defense-in-depth: limited DB privileges + encryption.
XSS beats CSRF token
XSS script runs in trusted origin → reads same-origin CSRF token → bypasses it unless carefully protected. CSRF abuses automatic cookie send, XSS injects script.
Web Privacy — extra MED
Session replay leak
3rd-party script records DOM, text, clicks, mouse, keypresses. Masking fails → passwords/grades/cards/health reach 3rd party. Spoof/Tamper/Disclosure . Violates Conf, Privacy, Authz. Fix: minimize scripts, strict masking, CSP, DPAs.
Mobile tracking
Advertising ID / IDFA shared across apps via SDKs, cross-app profile. ATT = iOS App Tracking Transparency permission. Fix: reset/disable ad ID, fewer apps, restrict permissions. Device-channel : app, user card, EXID, sensors → infer restricted data, bypass permission model.
CNAME tracking
First-party-looking subdomain aliases a hidden tracker domain → evades 3rd-party cookie blocking.
Supercookie / evercookie / ETag
Evercookie respawns ID from cookies+localStorage+IndexedDB+cache+ETag; clearing one store → restored from another. ETag = per-user cookie validator used as cookieless ID. Fix: clear ALL site data, partition caches.
Malvertising
Buy/compromise ad slot → user sees trusted-looking ad → redirect to malware/phishing. Spoof/Tamper/Disclosure/EoP . Violates Authenticity, Integrity, Conf, Authz.
Modern defenses
Total Cookie Protection / partitioning = separate cookies per profile/site. Safari ITP = classifies trackers + partitioned/time-limited cookies. Privacy Sandbox Topics API = browser-side interest topics, triggered after explicit user consent. Pseudonymization = (re-linkable via location/movement/aux data). Password rotation does NOT stop tracking .
Secure Computation — extra LOW
Reidentification
Remove name/SSN, but link quasi-identifiers (ZIP, birth date, sex) to aux datasets (voter records) → "anonymous" record tied to person. Info disclosure. Violates Privacy, Conf. Fix: DP, stronger anonymization, minimization.
Differential Privacy
Add calibrated noise (Laplace mechanism for numeric queries) → bound what output reveals about any record. Privacy budget (ε) : each query leaks bounded info; too many queries exhaust budget → higher leak. Output leakage : privacy trade-off. Fix: enforce budget, query auditing.
HE vs MPC
HE = 1 server computes on ciphertext, 1 query-response round, high cost; client must trust correctness unless verifiable (buggy/malicious server returns wrong result → Integrity/Accuracy fail). MPC ≥ 2 parties, trust distributed, interactive multi-round, often more efficient, network-sensitive.
HE flavors
PHE = unlimited ops of ONE type (add OR mult). SHE = add+mult, limited depth. FHE = unlimited add+mult.
MPC adversaries
Passive / honest-but-curious = follows protocol, records msgs, infers extra. Active / malicious = deviates arbitrarily, abuses, biases result. Spoof/Tamper/Disclosure/DoS . Honest majority = < half corrupt; dishonest majority = ≥ half (full-threshold = all-but-one). Active security costlier (commitments/MACs/ZK).
MPC building blocks
Secret-sharing MPC : linear ops local, multiplication interactive; good for LAN (minimize data transfer). Garbled circuit (Yao) : garbles encodes circuit; evaluator evaluates gate-by-gate; good for WAN (minimize rounds), function must be circuit in advance. Preprocessing/offline = data-independent random material; online = data-dependent, consumes it.
Data states
In transit, at rest, in use. Secure computation targets (yes/no) + combine with DP.
Final drill — T/F traps ans
"Mixing data + code = main SQLi cause" T. "HTTP stateless" T. "SOP prevents server-side cookie theft" F. "MACs may use hash functions" T. "ret2libe mitigated by CFI" T. "TLS protects cookies from theft" T for network, not all locations
"Fingerprinting relies on HTTP cookies" F. "Social-network access ctrl = MAC" F, DAC-like
"Public keys must stay secret" F, authenticity matters not secrecy. "Signature IDS = public-key source sig" F, attack patterns
2FA valid: PIN+biometric (know+are), token+password (have+know), voice+token (are+have)

Invald : PIN+password (both know), voice+token (both biometric/one category).
TLS select : conf msg, integrity msg, authenticity msg, server authenticity (client only if mutual TLS). NOT : confidentiality of parties, availability.
Exam quick-reference drill
Crypto math drills
Mod exp fast : 2 ³ mod 35: 2 ³ =32, 32<35 → 32. Square-and-multiply for big exp. Euler finds $d = e^{-1} \bmod \lambda$; $\lambda = \text{lcm}(\phi(p), \phi(q))$. Euler $\phi(p) = (p-1)(q-1)$; $\lambda = \text{lcm}(p-1, q-1)$. HD numeric : $p=23, q=5$; $a=6$ → $A=5^6 \bmod 23=8$; $b=15$; $m=5$ → $B=15^8 \bmod 23=19$; secret = $19^8 \bmod 23 = 2 = e^{15} \bmod 23$.
Hashing
SHA-256 =256-bit digest; SHA-3 =Keccak sponge. MD5/SHA-1 broken (collisions). BirthDay bound : collision after $\approx 2^{1/2}$ tries (256-bit). Properties: preimage (given h , find m), 2nd-preimage (given m_1 , find m_2 same hash), collision (find any $m_1 \neq m_2$ same hash). Collision easiest (birthday).
TLS internals
Handshake : negotiate cipher, auth via cert, key exchange (ECDHE = forward secrecy). Record : bulk encryption after $\approx 2^{1/2}$ tries (256-bit). Properties: ephemeral keys, past traffic safe if long-term key later leaked. Cert validation: check sig chain to trusted CA; FRR crossover. MFA needs ≥ 2 DIFFERENT categories.
Access-model star notation
Beil-LasPadula (conf): simple = no read up; +prop = no write down. Biba (integrity): no read down; +prop = no write up. Clark-Wilson : well-formed transactions + separation of duties + audit. Chinese Wall : dynamic, no access across conflict-of-interest classes once you've seen a competitor's data.
AC model pick
DAC =owner delegates (UNIX, social nets, GitHub). MAC =system labels, no delegate (military). RBAC =user → role → perms (enterprise). ABAC =attribute policy (context: time/IP/dept). EAB =contextual RBAC. FRR crossover. MFA needs ≥ 2 DIFFERENT categories.
Auth factors
Know (password/PIN), Have (token/card/phone), are (biometric). Fingerprint/iris/face=physiological; voice/typing/gait=behavioral. FAR =imposter accepted (Type II); FRR =legit rejected (Type I); EER =FRR crossover. MFA needs ≥ 2 DIFFERENT categories.
IDS precision (base rate)
Precision = $\frac{TP}{TP + FP}$. Rare attacks → even tiny FPR floods 30,000 alerts/floor. Worked: 10^6 pkts, 10 malicious. Det A: TPR 0.2, FPR 10^{-6} → TP,1 FPR=67%. Det B: TPR 0.9, FPR 5×10^{-6} → TP,50 FPR=15%. Pick higher precision (A vs B).
Last-second goal map
Spoof =Authenticity; Tamper =Integrity; Reput =Non-Rep/Accet; Disclosure =Conf/Privacy; DoS =Availability; EoP =Authz. Defense-in-depth : firewall, IDS, honeypot, log validation+encryption. Kerckhoffs : only the key is secret.
Comparison tables drill
Symmetric ciphers
DES : 64-bit block, 56-bit key (broken), 16 Feistel rounds 3DES : 112/168-bit effective, ~10/12.4 years. AES : 128-bit block, 128/192/256-bit key → 10/12.4 years. SP-network, fast+secure standard.
Public-key schemes
RSA : factoring hard; 2048+ bit; encrypt+sign. DH : discrete log; key exchange only. ECC : ECDLP; 256-bit=RSA 3072; ECDSA/ECDF, small keys. Quantum : discrete log, factoring, ECC all classical broken by Shor (quantum) → post-quantum (lattices).
Sym vs Asym
Sym: 1 shared key, fast, bulk, key-distribution problem. Asym: key pair, slow, small data (key exchange/sig), solves distribution. Hybrid = asym agrees session key → sym encrypts bulk.
Modes recap
ECB (leaky patterns) , CBC (IV chain, needs random IV), CFB (self-synch), OFB (CTR/no error propagation, stream cipher, never sees nonce), GCM (CTR+auth=AEAD).
Malware & social eng MED
Malware types
Virus = attaches to host file, needs user to run. Worm = self-propagates over network, no host. Trojan = disguised as legit. Ransomware = encrypts files, demands payment (Availability). Rootkit = hides presence, kernel/hook level. Botnet = compromised hosts under C2 used for DDoS/spam. Spyware/keylogger = covert data capture. Logic bomb = triggers on condition.
Social engineering
Phishing = mass fake email/site for creds. Spear phishing = targeted. Whaling = exec target. Pretexting = invented scenario. Baiting = malicious USB/CD/DKIM fail. Together reduce spoofing.
Vishing/smishing = voice/SMS. Fix: training, MFA, verify out-of-band, email filtering, DMARC/SPF/DKIM.
Email auth
SPF = which IPs may send for domain. DKIM = signed email headers. DMARC = policy for reporting on SPF/DKIM fail. Together reduce spoofing.
Side-channels & misc LOW
Side-channel attacks
Timing = exec time leaks secret (compare/branch). Power analysis (SPA/DPA) = power trace leaks key. Cache (Spectre/Meltdown) = cache timing leaks across boundary. EM/acoustic = emanations. Fix: constant-time code, blinding, masking.
Clickjacking
Invisible iframe over legit-looking button → user clicks unintended action. Fix: X-Frame-Options , frame-ancestors (CSP).
CORS
Server opt-in relaxation of SOP via Access-Control-Allow-Origin. Access-Control-Allow-Origin (with credentials) → cross-origin data theft.
Certificate revocation
CRL = list of revoked cert serials. OCSP = online status query. OCSP stapling = server attaches fresh status. Revoke on key compromise/CA breach.
Master attack map ref
attack → STRIDE+goal+fix: SQLi : Tamper/Disclosure/EoP; Conf/Integ/Authz; prepared stmt. XSS : Tamper/Spoof/Disclosure; Conf/Integ; encode+CSP+HttpOnly. CSRF : Spoof/Tamper; Authz/Integ; token+SameSite. Buf overflow : Tamper/EoP; Conf/Integ/Authz; canary. ROP/ret2libe : EoP; Integ; CFI+shadow stack. MITM : Spoof/Tamper/Disclosure; Auth/Conf/Integ; TLS. SYN flood : DoS; Avail; SYN cookies. DNS poison : Spoof/Tamper; Authenticity/Integ; Heartbleed : Spoof/Tamper; Conf; patch-bounds. Phishing : Spoof; Auth; MFA+training. Priv : EoP; Auth; least privilege. Tracking : Disclosure; Privacy; block 3rd-party+anti-fp.